

통 보

1. 제 목 : 업무망 서버 관리 및 정보보안에 관한 사항

2. 관계기관 : XXXX병원

3. 내 용

우리 공단은 네트워크 포트에 관한 국제적 관리기준을 적용하여 정보통신망을 운영·관리하고 있습니다.

나. 관계법령 및 판단기준

네트워크 포트란 동일한 기기 내에서 독립적으로 실행 중인 여러 프로세스 간의 통신을 구분하기 위한 논리적 식별자(Logical Identifier)로서, 국제 인터넷 주소관리기구(ICANN) 산하 IANA(Internet Assigned Numbers Authority)가 관리하고 있습니다.

IANA에서는 포트를 용도별로 [표 1]과 같이 #개 구역으로 나누어 운영하고 있습니다.

[표 1] IANA에서 관리하는 포트 구분

종류	다른 명칭	범위	설명
시스템 포트	잘 알려진 포트(Well-Known ports)		주요 프로토콜(HTTP, SSH, FTP 등)
유저 포트	등록된 포트(Registered ports)		IANA에 의해 사용처가 등재된 포트
동적 포트	휘발 포트(Ephemeral ports), 개인포트(Portable ports)		클라이언트용 단기 포트

특히 시스템 포트(###)는 네트워크 통신을 위해 자주 쓰이는 서비스를 국제표준에 따라 특정 서비스로 할당한 포트들로, 보안상 제한하거나 시스템 관

리자 전용으로 사용해야 하는 포트가 다수 존재합니다. 또한 유저 포트(###) 중에서도 웹 응용관리용(### 등) 또는 데이터베이스 관리용(### 등)과 같이 외부 접근 시 보안상 취약점을 유발할 수 있는 포트가 있어, 이들 역시 내부 관리망에서만 접근하도록 제한해야 하며, 주요 포트의 용도와 보안상 유의사항은 [표 2]와 같습니다.

[표 2] 보안상 제한되거나 시스템 관리자만 사용 가능한 주요 포트

포트 번호	포트 구분	프로토콜	주요 용도	보안상 유의 사항
###	시스템 포트	FTP	파일 전송(평문 통신)	비암호화 전송으로 계정·파일 유출 위험, 사용 금지 또는 SFTP 전환
###		SSH	원격 터미널 접속	포트(###) 변경 및 접근 IP 제한 등
###		HTTP	웹서비스(평문 통신)	HTTPS(###)기반 암호화 전환 필요
###	유저 포트	Oracle TNS Listener	오라클 DB 접속	DB관리자 및 서버 전용 접근 허용
###		MySQL	DB 접속	DB관리자 및 서버 전용 접근 허용
###		Application/ Web Admin	응용서비스 관리포트	외부 접근 차단, 관리자 전용 제한

한편 「정보보안업무 처리지침」 제22조(서버 보안관리)에서는 불필요한 서비스 포트를 제거하고, 관리용 포트와 사용자용 포트를 분리하며, 관리용 포트의 접속은 특정 IP·MAC 단말에서만 가능하도록 제한하도록 규정하고 있습니다.

또한 같은 지침 제30조(네트워크장비 보안관리)에서는 시스템 관리자가 라우터·스위치 등 네트워크 장비 운용 시 RLOGIN, RSH, RCP, FTP, TELNET 등 평문 전송 서비스 사용을 금지하고, 불필요한 서비스 포트는 차단하도록 명시하고 있습니다.

다. 감사결과 확인된 문제점

그런데 XXXX병원에서 운영 중인 업무망 서버 및 네트워크 장비의 포트를 확인한 결과, 일반 사용자 단말(PC) 대역에서 [표 3]과 같이 주요 서버(DB, EMR 등)의 서비스 포트가 개방되어 있는 것으로 확인되었습니다. 이는 불필요한 포트 차단, 관리용 포트 분리, 평문 서비스 금지 등에 관한 규정을 준수하지 못한 사항으로, 내부망 단말로부터 주요 서버에 직접 접근이 가능한 보안 취약점이 존재함을 확인하였습니다.

[표 3] 업무망 내 주요 포트 개방 현황

구분	포트번호	서비스(프로토콜)	문제점
네트워크 장비	###	SSH	관리자 포트 접근통제 미흡
DB서버	###	FTP, HTTP, Oracle Listener, Application Port	내부자 접근·정보 유출 위험
DB보안 서버	###	MySQL, Admin Port	DB 접근통제·관리권한 관리 미흡

(자료: XXXX병원 제공자료 재구성)

4. 관계기관 의견

XXXX병원에서는 감사결과를 수용하여 별다른 의견을 제시하지 않았습니다.

5. 조치할 사항

○ XXXX병원장은

- 일반사용자 대역에서 보안상 제한이 필요한 시스템 포트(### 등) 및 관리자 접근만 허용되어야 하는 유저 포트(###)에 대하여 포트 변경, 접근 IP 제한 등 필요한 보안조치를 이행하여 주시기 바랍니다. (통보)